

Segurança da Informação (S.I.)

Malwares

Prof. Me. Euclides Nasorri Gottsfritz
euclides.gottsfritz@ifsp.edu.br



INSTITUTO FEDERAL
São Paulo
Campus Catanduva

Agenda



- Revisão;
- Malwares;
 - O que são?;
 - Tipos;
 - Propagação;
 - Prevenção;
- Considerações Finais



Revisão

Revisão

- Na aula passada estudamos um pouco sobre Riscos;
 - Probabilidade de Prejuízo em razão de algo ou alguém;

- Possui 3 fatores e 1 Razão;

- Fatores:

$$R = \frac{V \times A \times I}{M}$$

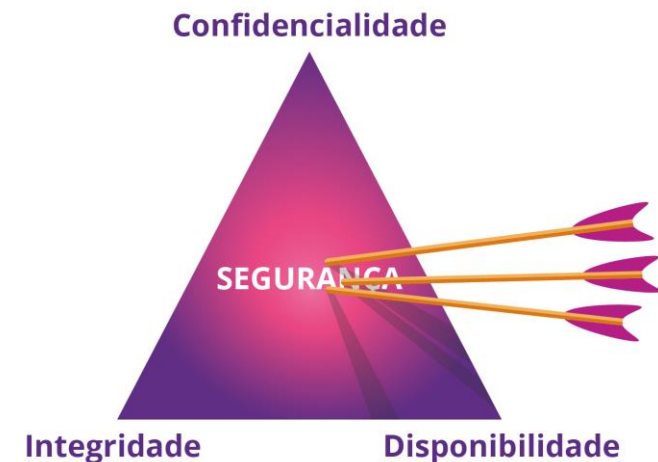
RISCO VULNERABILIDADES AMEAÇAS IMPACTOS

MEDIDAS DE SEGURANÇA

- **Vulnerabilidades:** Qualquer fraqueza que possa ser utilizada para comprometer a segurança de sistemas ou informações;
- **Ameaças:** São Agentes que potencialmente podem comprometer a Confidencialidade, Integridade e Disponibilidade da Informação dada as Vulnerabilidades;
- **Impactos:** Unidade de medida utilizada para mensurar os danos causados por um incidente de segurança;

Revisão

- Razão:
 - **Medidas de Segurança:** São meios para mitigar as vulnerabilidades e consequentemente, neutralizar a Ameaça.
- Vulnerabilidades são divididas em 7 tipos de Fontes:
 - Comunicação, Instalações, Hardware, Humanas, Mídias, Naturais, Software.
- Ameaças têm 3 tipos de Origem:
 - Ambientais, Deliberadas e Acidentais.
- Impacto
 - Exemplo do Enem vazado 90 dias e 48 horas antes da prova.



Revisão

- Medidas de Segurança são divididas em 3 grupos dadas as características:
 - Preventivas, Detectivas e Corretivas.
 - Também vimos sobre as 6 Barreiras e suas funcionalidades.
- Também percebemos que uma Vulnerabilidade sem Impacto, não possui Risco para a empresa. O mesmo vale para Ameaças e Vulnerabilidades.

AMEAÇAS	
1ª BARREIRA	DESENCORAJAR
2ª BARREIRA	DIFICULTAR
3ª BARREIRA	DISCRIMINAR
4ª BARREIRA	DETECTAR
5ª BARREIRA	DETER
6ª BARREIRA	DIAGNOSTICAR
ATIVOS	

Revisão

- Vimos que os **Agentes/Atacantes** irão buscar formas de **contornar as Barreiras** e **Explorar as Vulnerabilidades**;
- E que para propor um projeto de segurança é necessário **entender a empresa**;
 - **Conhecer** o **ambiente**, os **processos**, os **controles** implementados e **avaliar o índice de Riscos**;
- O projeto de segurança precisa possuir **controles** que após implementados sejam **monitorados, analisados e melhorados**;
 - Além de estarem de acordo com as **legislações** e **normatizações** (LGPD e as ISOs da série 27000);





Malwares

Malwares



- Malware vem da **abreviação** do termo “Software Malicioso” em Inglês, **Malicious Soft**ware;
- São programas que **executam ações danosas e maliciosas**, além de serem utilizados como intermediários para prática de Golpes, realização de Ataques e envio de Spam;

Malwares



- Eles são capazes de **infectar** diversos tipos de **dispositivos**, além de assumir diversas formas;
- Eles costumam **explorar vulnerabilidades** existentes, ou **criar** uma **vulnerabilidade** para ser explorada por outro Malware ou um Atacante;

Malwares

- Eles podem ser **introduzidos** em um dispositivo através de um **e-mail** com um anexo ou link malicioso, Engenharia Social ou **pen-drive**;
- A melhor **prevenção é impedir a infecção** inicial, já que podem ser difíceis de identificar e dificilmente conseguirá reverter os danos sofridos;



Malwares



- Já um **Atacante**, é uma **pessoa** normalmente **mau intencionada**, que procura formas de subjugar um sistema, para obter acesso a processos ou informações;
 - Podem ser **motivados por diversos fatores**: Vingança, Espionagem, Ciberterrorismo, etc;
 - A mídia costuma nomeá-los como “Hackers”, mas veremos essa diferença mais para frente.

Malwares



- A algum tempo atrás, a criação de **Malwares** era um “**hobby**” relativamente comum de **entusiastas** da programação e informática;
- Era comum enquanto (eu) adolescente recebermos de outros amigos e colegas arquivos por e-mail ou disquete que na realidade continham um Malware;
- **Não eram** softwares **nocivos** ou que causasse prejuízos financeiros, **apenas contratempos** e alguma **bagunça**;

Malwares

- Porém isso deixou de ser brincadeira a algum tempo, quando **criminosos** perceberam que poderiam se **aproveitar** desse tipo de funcionalidade para **ganho próprio**;
- Esses **criminosos** são comumente **especializados** em crimes cibernéticos e empregam várias táticas na tentativa de **obter dados** pessoais vendáveis ou **extorquir dinheiro** das vítimas;



Malwares - Tipos



- Existe uma variedade de **Malwares**, **definidos** de acordo com sua **função** e ação;
- Conhecer suas **características** nos **auxilia** a **detecta-los** e corrigi-los;
 - Também permite estimar o tipo de dano e a abrangência dele.

Malwares – Vírus

- É um **pedaço de código** capaz de se integrar a Programas e Arquivos;
- Esse código é **executando** juntamente com o Programa/Arquivo infectado;
- O Vírus fica **inativo** até a abertura do Programa ou Arquivo infectado;



Malwares – Vírus

- Após executado ele poderá se **propagar** através dos **sistemas**, **mensagens** e **e-mails**, além das demais rotinas programadas para sua execução;
- Apesar de não ser popular na atualidade, seu nome é utilizado **erroneamente** como sinônimo de Malware (Código Malicioso);



Malwares – Vírus

- **Stuxnet:**
 - Surgiu em 2010 e sua infecção se iniciou através de uma **unidade USB** infectada, ou seja, um ataque direcionado;
 - Ele foi escrito para **causar falhas** em sistemas de **controle industrial** da Siemens;



Malwares – Vírus

- **Stuxnet:**
 - Especula-se que ele tenha sido desenvolvido pelo governo americano para atingir o [programa nuclear iraniano](#);
 - Coincidentemente, o Stuxnet infectou cerca de **20 mil computadores** e destruiu **20% das centrífugas** nucleares iranianas.



NEWS

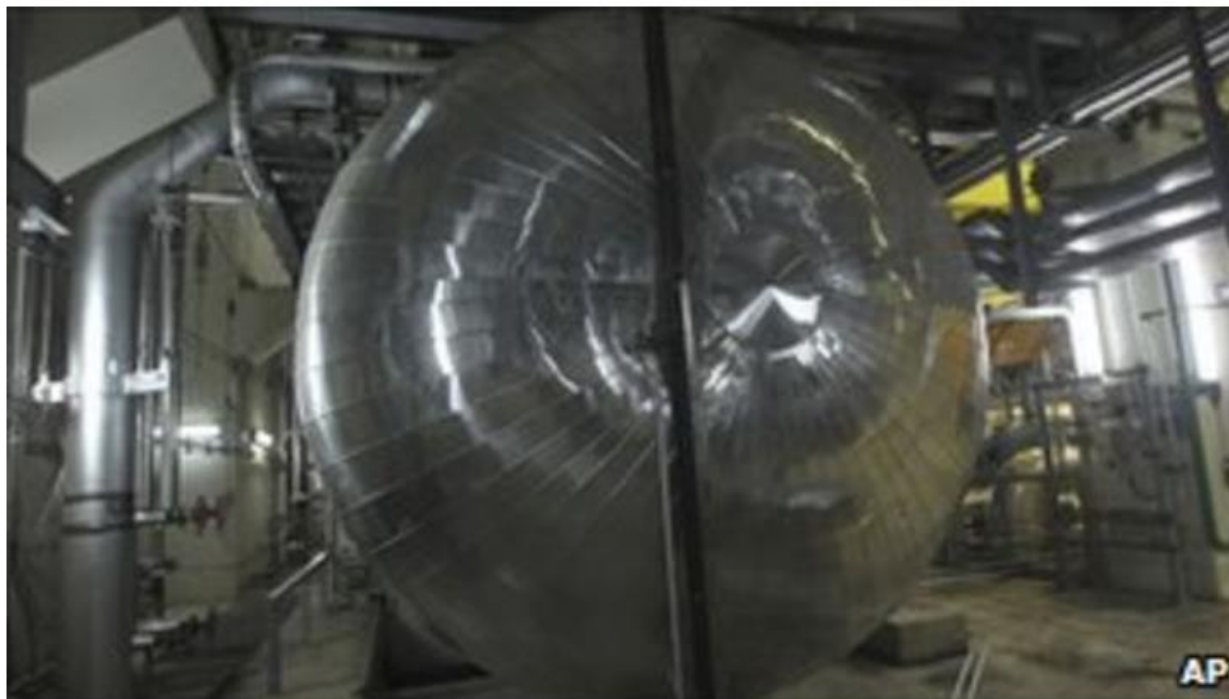
[Home](#) | [Israel-Gaza war](#) | [War in Ukraine](#) | [India Election 2024](#) | [Climate](#) | [Video](#) | [World](#) | [US & Ca](#)[Tech](#)

Stuxnet virus targets and spread revealed

🕒 15 February 2011



Fonte: <https://www.bbc.com/news/technology-12465688>



Malwares – Ransomware



- Esse tipo de Malware é capaz de tornar todo o **sistema operacional** e/ou **armazenamento** de arquivos do dispositivo **inacessível** através de criptografia;
- Após a infecção, ele irá **pedir resgate** para lhe devolver os dados ou não vaza-los;

Malwares – Ransomware



- O dispositivo infectado exibirá uma mensagem com os procedimentos necessários para **realizar** esse **pagamento**;
- Nesses procedimentos estão, além do **valor**, o **prazo**, a **identificação** do dispositivo e até a forma de contato com o Atacante.

Malwares – Ransomware



- **CriptoLocker:**

- Através de **Engenharia Social**, os Atacantes enganavam funcionários de empresas para **baixarem** um arquivo infectado com o **Ransomware**.
- Após o download, o CriptoLocker travava o computador e exibia uma mensagem ofertando a **descriptografia** dos arquivos **por Bitcoins**, dentro de um prazo;

Malwares – Ransomware



- **CriptoLocker:**
 - Apesar de ter sido desativado desde 2014, **estima-se** que seus criadores conseguiram extorquir cerca de **3 Milhões de Dólares** dentre todas as organizações infectadas.

Your personal files are encrypted!



Private key will be destroyed on
9/13/2013
9:11 AM

Time left
71 : 59 : 48

Your important files **encryption** produced on this computer: photos, videos, documents, etc. [Here](#) is a complete list of encrypted files, and you can personally verify this.

Encryption was produced using a **unique** public key **RSA-2048** generated for this computer. To decrypt files you need to obtain the **private key**.

The **single copy** of the private key, which will allow you to decrypt the files, located on a secret server on the Internet; the server will **destroy** the key after a time specified in this window. After that, **nobody and never will be able** to restore files...

To obtain the private key for this computer, which will automatically decrypt files, you need to pay **300 USD / 300 EUR /** similar amount in another currency.

Click «Next» to select the method of payment and the currency.

Any attempt to remove or damage this software will lead to the immediate destruction of the private key by server.

Next >>

Payment for private key



Private key will be destroyed on
9/20/2013
6:48 PM

Time left
71 : 58 : 56

Choose a convenient payment method:

MoneyPak (USA only)



MoneyPak is an easy and convenient way to send money to where you need it. The MoneyPak works as a 'cash top-up card'.

Where can I purchase a MoneyPak?

MoneyPak can be purchased at thousands of stores nationwide, including major retailers such as Walmart, Walgreens, CVS/pharmacy, Rite Aid, Kmart and Kroger. Click [here](#) to find a store near you.

How do I buy a MoneyPak at the store?

Pick up a MoneyPak from the Prepaid Product Section or Green Dot display and take it to the register. The cashier will collect your cash and load it onto the MoneyPak.

[Home Page](#)

[MoneyPak Store Locator](#)

Enter the card number and press «Pay»:

300 USD



<< Back

PAY

Malwares – Ransomware

RIBEIRÃO E FRANCA 

Após ciberataque, Hospital de Câncer de Barretos estima 5 dias para normalizar atendimentos em todo o país

Variante do Ransomware Petya

Unidade teve 3 mil consultas e exames suspensos na terça-feira (27) após hackers pedirem resgate em bitcoins para desbloquear sistemas. CPU será periciada em Brasília (DF).

Por Jornal da EPTV 1ª Edição
28/06/2017 12h30 · Atualizado há 7 anos

Fonte: <https://g1.globo.com/sp/ribeirao-preto-franca/noticia/apos-ciberataque-hospital-de-cancer-de-barretos-estima-5-dias-para-normalizar-atendimentos-em-todo-o-pais.ghtml>

Malwares – Ransomware

Doops. your important files are encrypted.

If you see this text, then your files are no longer accessible, because they have been encrypted. Perhaps you are busy looking for a way to recover your files, but don't waste your time. Nobody can recover your files without our decryption service.

We guarantee that you can recover all your files safely and easily. All you need to do is submit the payment and purchase the decryption key.

Please follow the instructions:

1. Send \$300 worth of Bitcoin to following address:

1Mz7153HMuxXTuR2R1t78mGSdzaAtNbBWx

2. Send your Bitcoin wallet ID and personal installation key to e-mail wowsmith123456@posteo.net. Your personal installation key:

w0TGT7-2K3MCT-dTFY1Y-WdxgAN-nvuWN6-fBJAGL-DxWNzw-qj9njU-FS4FCc-JoQoUQ

If you already purchased your key, please enter it below.

Key: _

Malwares – Spyware

- **Monitora** as atividades de um **dispositivo** para **capturar informações** e envia-las ao Atacante;
- Ele pode se espalhar explorando **vulnerabilidades de software** ou através de outro Malware;
- Possui basicamente **4 subtipos**, cada um com sua especialidade:
 - Keylogger, Screenlogger, Adware e Stalkerware.



Malwares – Spyware Keylogger

- Captura e armazena as teclas digitadas;
- Pode realizar a captura na totalidade, desde o boot do sistema operacional até seu desligamento;
- Ou pode realizar a captura somente ao acessar um site específico, de Internet Banking por exemplo.



Malwares – Spyware Screenlogger

- Tem a função de **armazenar** a posição do **cursor e a tela** do computador (ou região em volta do cursor) **no momento do clique** do mouse;
- Também é **possível configurá-lo** para capturar a tela após uma determinada sequência de teclas serem digitadas.



Malwares – Spyware Adware



- Basicamente ele é projetado para **apresentar Banners e Anúncios**, normalmente em forma de Pop-Up;
- Ao mostrar anúncios para os usuários, tem-se um **aumento de visualização** o que consequentemente gera **renda**;
- Porém, esses anúncios podem levar a **golpes e fraudes**.

Malwares – Spyware Stalkerware



- É projetado para **espionar** as atividades do **dono do dispositivo**;
- Obviamente, que essa pessoa não autorizou e **não sabe da existência** desse Malware;
- As informações coletadas são enviadas para quem o projetou, o **Stalker**.

Malwares – Spyware



- **Fireball:** foi um **Adware** datado de 2017 que infectou grande parte dos computadores do mundo. Ele **afeta o navegador**, alterando a página inicial para um falso motor de busca. Ele também **insere anúncios** em qualquer página web visitada, além de não permitir que você altere as configurações do navegador;

Malwares – Spyware



Fireball: vírus infecta mais 250 milhões e transforma PC em zumbi

Malware transforma afeta navegadores mas pode roubar dados sensíveis de usuários

Por João Kurtz, para o TechTudo

02/06/2017 16h44 · Atualizado há 7 anos

Fonte: <https://www.techtudo.com.br/noticias/2017/06/fireball-virus-infecta-mais-250-milhoes-e-transforma-pc-em-zumbi.ghtml>

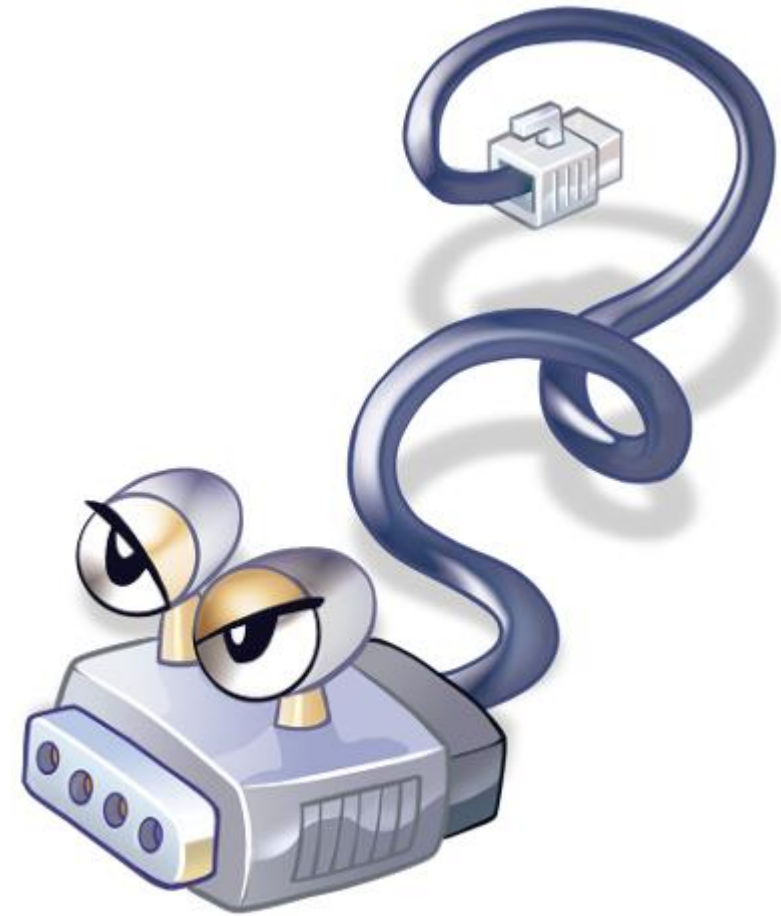
Malwares – Spyware



- **CoolWebSearch:** explorava vulnerabilidades do Internet Explorer para “sequestrar” o navegador, alterar suas configurações e enviar dados de navegação ao Atacante;
- **Gator:** Era empacotado junto com o Kazaa, e monitorava os hábitos de navegação para sugerir anúncios específicos no aplicativo;

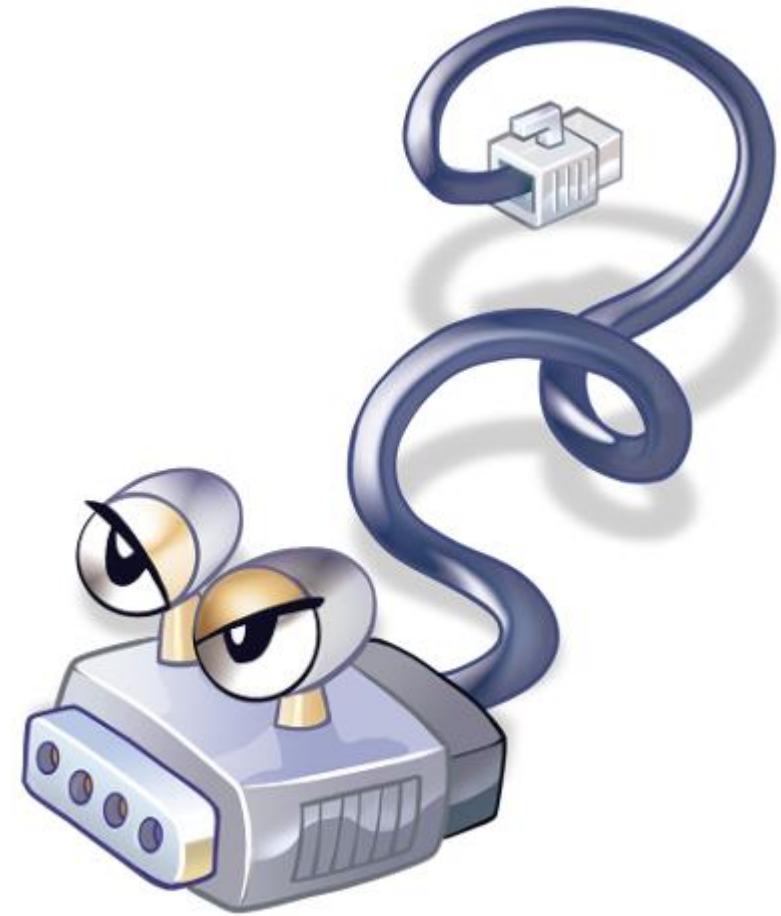
Malwares – Worm

- É um **programa independente**, capaz de se **replicar** e **infectar** outros dispositivos sem exigir ação de ninguém;
- São comumente capazes de **detectar vulnerabilidade** em sistemas e dispositivos da rede e usa-las **para** sua **disseminação**;
- São frequentemente **usados** para execução de “**carga útil**”, ou seja um código criado para danificar um sistema;



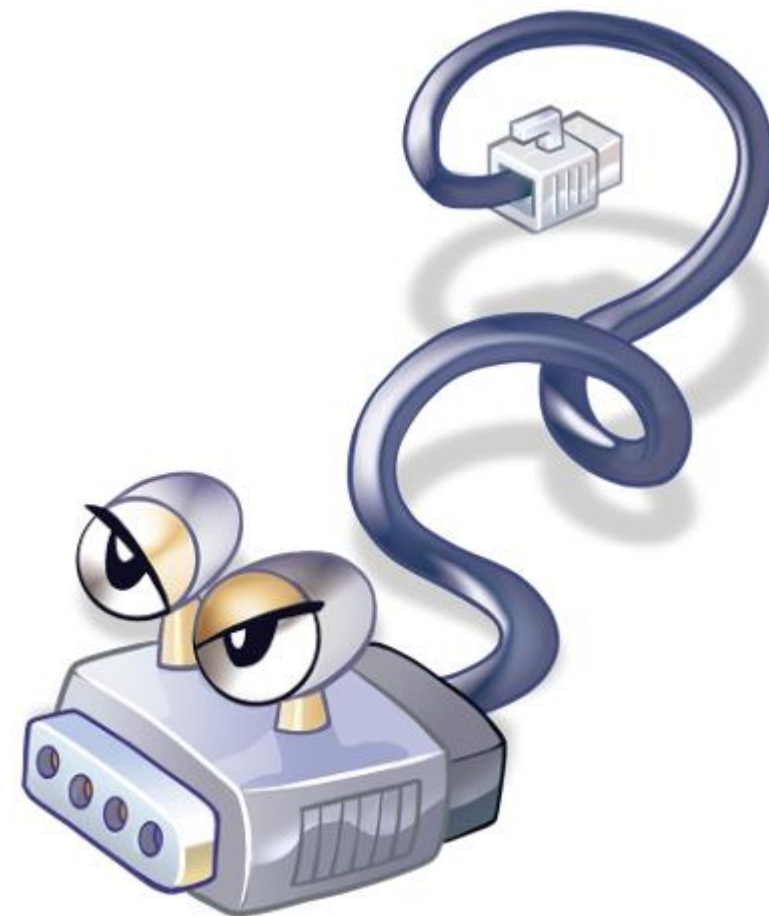
Malwares – Worm

- Essa “carga útil” é capaz de excluir arquivos, criptografar dados para um Ransomware, roubar informações, etc;
- Também pode ser responsável pelo consumo excessivo de recursos computacionais, o que afeta o desempenho de redes e dispositivos;



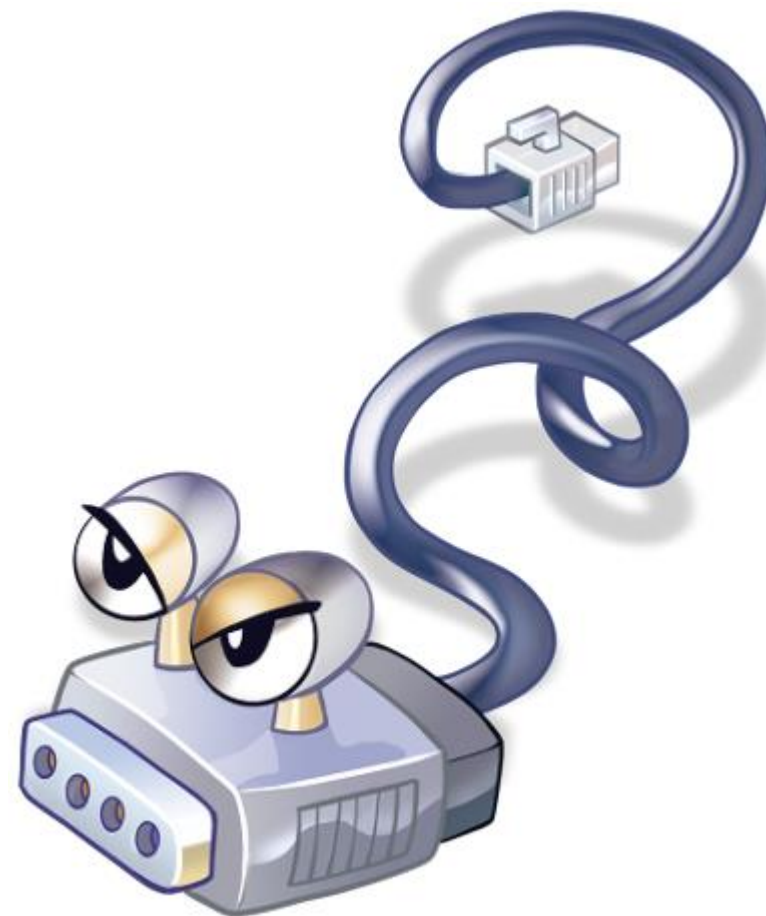
Malwares – Worm

- **SQL Slammer:**
 - Ele foi capaz de gerar endereços IP aleatórios e se enviar para eles na **procura de sistemas sem “AntiVirus”** para infecção;
 - Em 2003, cerca de **75 mil computadores** infectados com ele foram **utilizados** para um **Ataque DDoS** contra vários sites;



Malwares – Worm

- **SQL Slammer:**
 - Pouco tempo depois, um patch de segurança corrigiu a vulnerabilidade explorada, mas mesmo assim em 2016~2017 ele ressurgiu devido a sistemas desatualizados;



Malwares – Worm



ASSINE A FOLHA

ATENDIMENTO

FOLHA DE S. PAULO

★ ★ ★ UM JORNAL A SERVIÇO DO BRASIL

DOMINGO, 25 DE AGOSTO DE 2024 23H16

Opinião -

Política -

Mundo -

Economia -

Cotidiano -

Esporte -

Cultura -

F5 -

Tec -

Classifica

ÚLTIMAS NOTÍCIAS

tec



Maior | Menor



Enviar por e-mail



Comunicar erros



Link



Siga a Fo

05/02/2003 - 14h57

Mais rápido dos vírus, SQL Slammer espalhou-se em dez minutos

da Folha Online

PUBLICIDADE



er

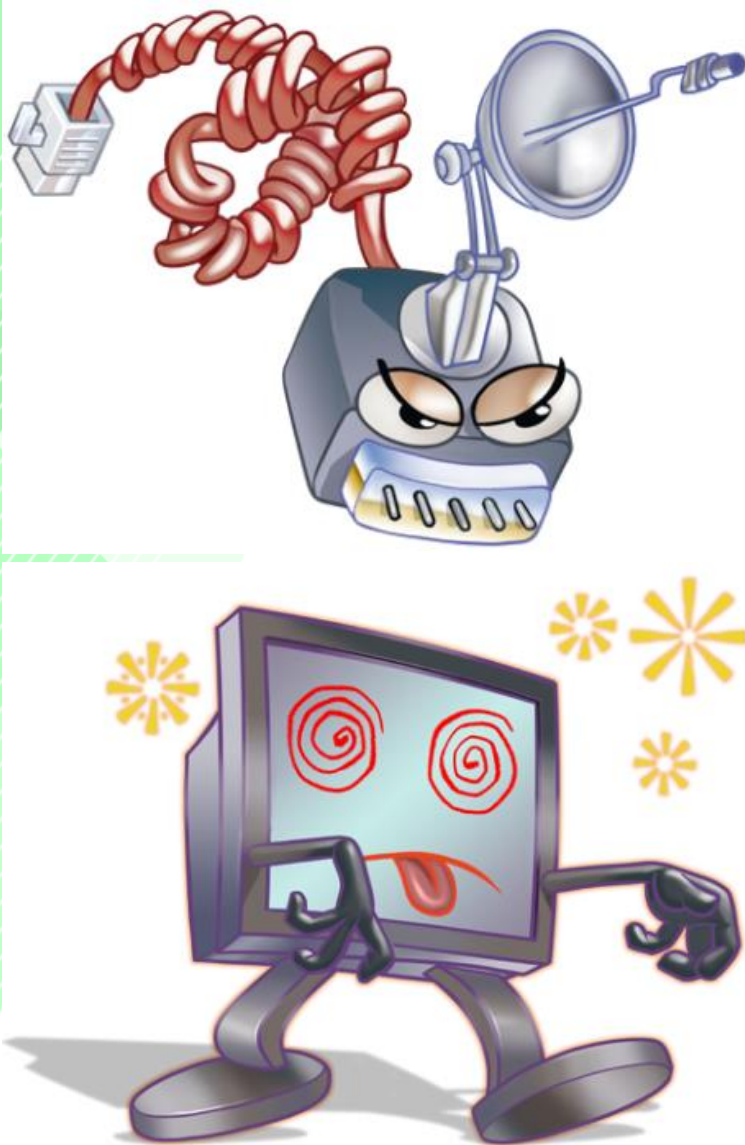
Fo



INSTITUTO
FEDERAL
São Paulo

Câmpus
Catanduva

Fonte: <https://www1.folha.uol.com.br/folha/informatica/ult124u12205.shtml>



Malwares – Bot

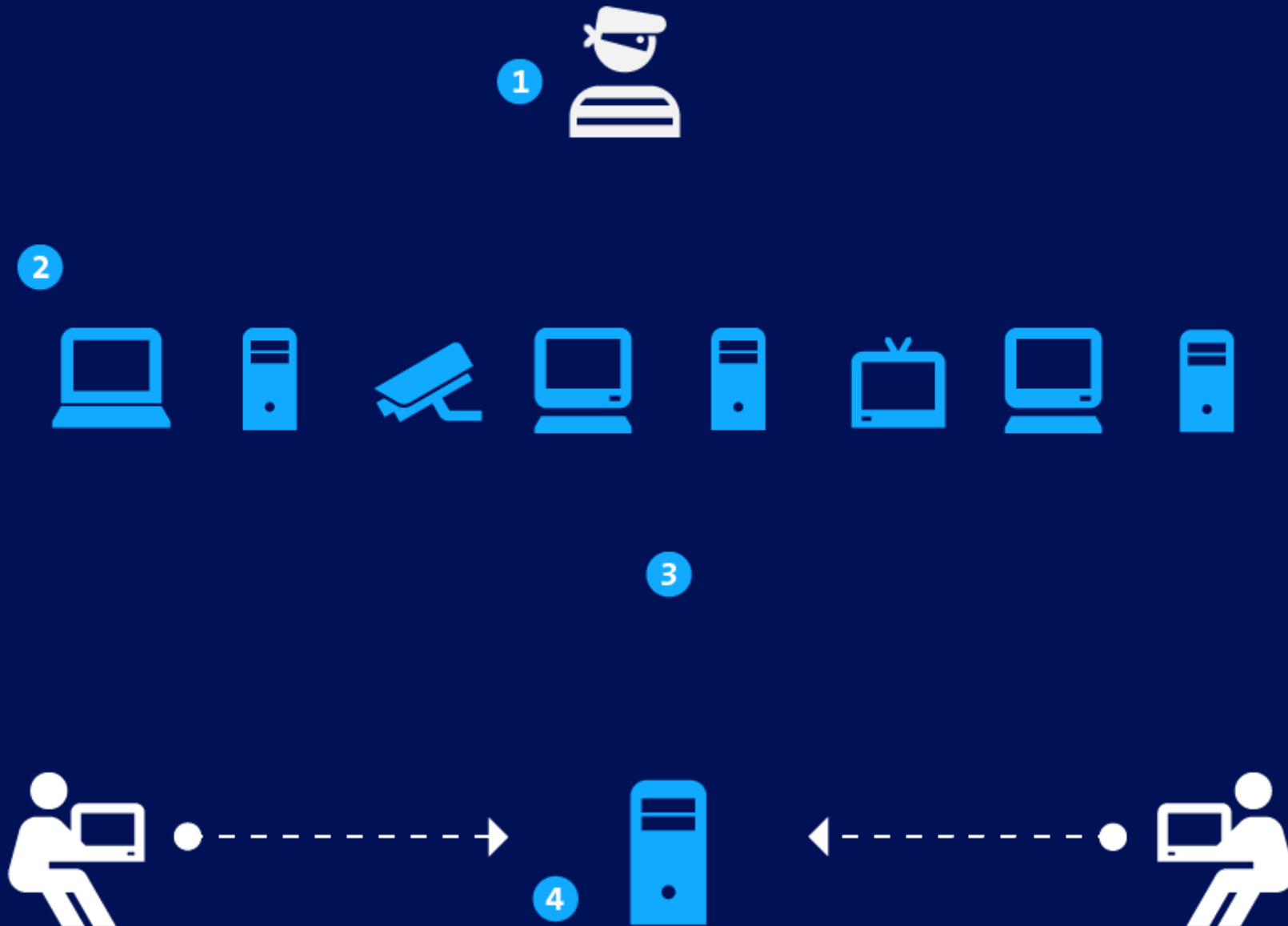
- Similar ao Worm, **alta capacidade de replicação**;
- Porém, esse possui **capacidade de comunicação** com o Atacante que o disseminou;
- Essa comunicação acontece para que o Atacante possa ter **controle remotamente**;
- O dispositivo infectado por esse Malware é chamado de Bot ou **Zumbi**;

Malwares – Botnet

- É uma **rede formada** por dispositivos **Zumbis**;
- Quanto **maior a quantidade de Zumbis**, e suas capacidades de conexão e processamento, **mais forte será a Botnet**;
- Exemplo de funcionalidades:
 - DDoS, Propagação de Malware, Coleta de Informações Pessoais, Envio de Spam, Mineração de Criptomoeda, etc;



How a DDoS attack works



Malwares – Botnet

- **Andromeda:**

- Em seu ápice, essa Botnet era capaz de **recrutar** cerca de **1 milhão** de novos dispositivos **por mês**;
- Essa infecção era através de redes sociais, mensagens instantâneas, emails de Spam, etc;
- A operação foi **derrubada pelo FBI e Europol** em 2017, mas estimasse que sua infecção nunca parou de ocorrer devido a sua automação.



Malwares – Botnet

- **Mirai:**

- Essa Botnet **infecta dispositivos IoT**, que possui **arquitetura** de processamento **ARC**;
- Seu primeiro uso em larga escala foi em 2016 para **derrubar** grande parte da **internet** da **Costa Leste** dos **EUA** através de um ataque DDoS;
- Apesar de poder ser mitigado, o Mirai ainda causa danos atualmente;



Malwares – Botnet



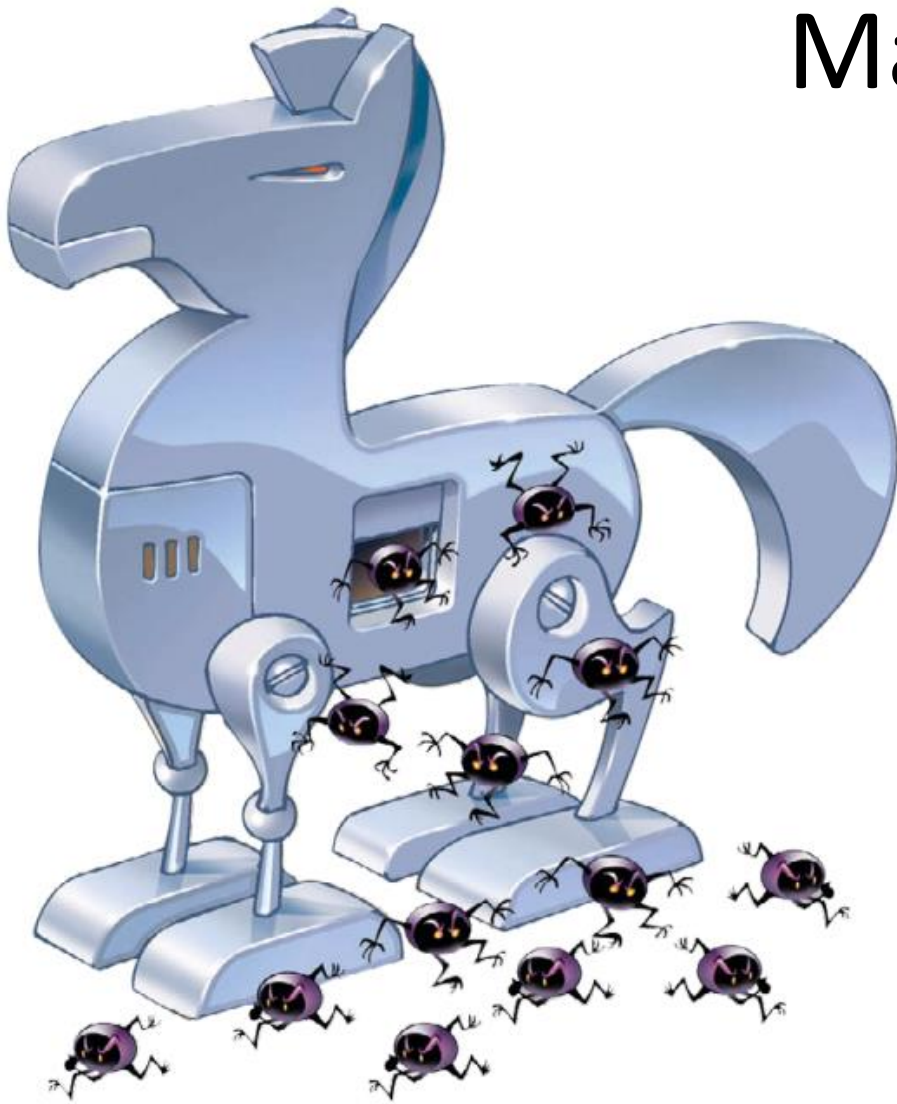
Botnet Mirai: ameaça sofisticada põe dispositivos IoT pessoais em risco

A ESET alerta para a importância dos cuidados com a segurança em dispositivos domésticos conectados à internet e seus possíveis riscos

Por: Redação | setembro 5, 2023 | Overview

Fonte: <https://securityleaders.com.br/botnet-mirai-ameaca-sofisticada-poe-dispositivos-iot-pessoais-em-risco/>

Malwares – Trojan



- Seu nome vêm da **mitologia grega**, onde na guerra de Tróia os gregos fingiram se render e entregaram aos Troianos um “presente”.
- Um **cavalo gigante** feito em madeira e cheio de soldados Gregos, que ao anoitecer abriram os portões da cidade de Tróia permitindo a invasão e dominação grega;

Malwares – Trojan



- Paralelo à mitologia, o **Trojan** é um software que **aparentemente cumpre com as funções** para o qual você o instalou;
- **Porém**, ele também **executa atividades maliciosas** das mais variadas através de sub-rotinas ou instalação de outro Malware;

Malwares – Trojan



- **Qbot:** Ativo desde 2007, é um Trojan **focado** em **roubar** dados de usuários e **credenciais bancárias**. Ao longo dos anos, ele evoluiu para empregar novos mecanismos de entrega, técnicas de controle e anti-análise;
- **TrickBot:** Identificado em 2016, foi desenvolvido para **roubo de dados bancários**, mas evoluiu para ser um **Malware Modular**, com uma variedade de ferramentas a serem utilizadas pelos Atacantes;

Malwares – Trojan

🔍 Buscar

tech**tudo** | Segurança

250 milhões de e-mails podem ter sido hackeados pelo malware Trickbot

Base de dados, que inclui milhões de contas do Gmail, Hotmail e de governos, foi usada para espalhar vírus na Internet com propósitos financeiros

Por Mariana Coutinho, para o TechTudo

16/07/2019 09h30 · Atualizado



Fonte: <https://www.techtudo.com.br/noticias/2019/07/250-milhoes-de-e-mails-podem-ter-sido-hackeadas-pelo-malware-trickbot.ghtml>

Malwares – Backdoor

- Sua função é permitir a **entrada** de um **Atacante** ou de outro **Malware** em um dispositivo;
- Isso se dá por meio da **criação** ou modificação de um **serviço vulnerável**;
- Ele também pode ser **instalado** por outro **Malware** ou um **Atacante** que já entrou no sistema por outra vulnerabilidade.



Malwares – Backdoor

- **MyDoom:**
 - Apesar de ser considerado um Worm, o MyDoom habilita a **porta 3127/TCP** e insere o arquivo SHIMGAPI.DLL na pasta System32 do Windows;
 - Com a primeira etapa pronta, ele é capaz de **corromper o Windows Explorer** para ter acesso aos arquivos e conseguir se propagar;
 - Sua **disseminação** é por **e-mail**, além de utilizar o dispositivo infectado como Botnet;





This page has been archived and is no longer updated.

[Find out more about page archiving.](#)

Atualizado às:

Fonte: https://www.bbc.com/portuguese/ciencia/story/2004/01/040130_virusqaebc



Envie por e-mail



Versão para impressão

Tire suas dúvidas sobre o vírus Mydoom

O vírus Mydoom começou a ser detectado por volta de 26 de janeiro, mas já está sendo considerado o vírus mais contagioso de todos os tempos.

Leia o texto abaixo para entender o que é esse vírus, de onde ele veio e como você pode se proteger dele.

O que é o Mydoom?

Mydoom é o último de uma longa geração de programas mal-intencionados que exploram falhas nos softwares da Microsoft.

Esse vírus aproveita buracos no Outlook (gerenciador de e-mails) e invade o catálogo de endereços do usuário, usando os que encontra para se auto-enviar a todos os endereços da lista.



Vírus não causa danos imediatos aos computadores



INSTITUTO
FEDERAL
São Paulo

Câmpus
Catanduva

Malwares – Remote Access Trojan (RAT)



- Basicamente é um **Trojan** que permite ao Atacante **acessar** o dispositivo infectado **remotamente**;
- Ou seja, combina características do **Trojan** (enganar o usuário) e do **Backdoor** (da acesso não autorizado ao Atacante)

Malwares – RAT



- **Rafel RAT:**
 - É um Malware de código aberto que **ataca sistemas Android**, principalmente versões antigas;
 - Ele é capaz de **fornecer** ao atacante **acesso remoto** ao dispositivo, além de viabilizar desde **roubo de informações** até criptografia de dados;
 - Sua **disseminação** é através de campanhas de **phishing** onde o usuário faz download do arquivo infectado;

Malwares – RAT



[Home](#) [Quem Somos](#) [Funcionalidades](#) [Parceiros](#) [Cases](#) [Conteúdo Rico](#) [Nós na imprensa](#) [Blog](#) [Contato](#)

[ODIN IA](#)

[Login](#)

[Teste](#)

Rafel RAT: Como proteger dispositivos Android do novo malware

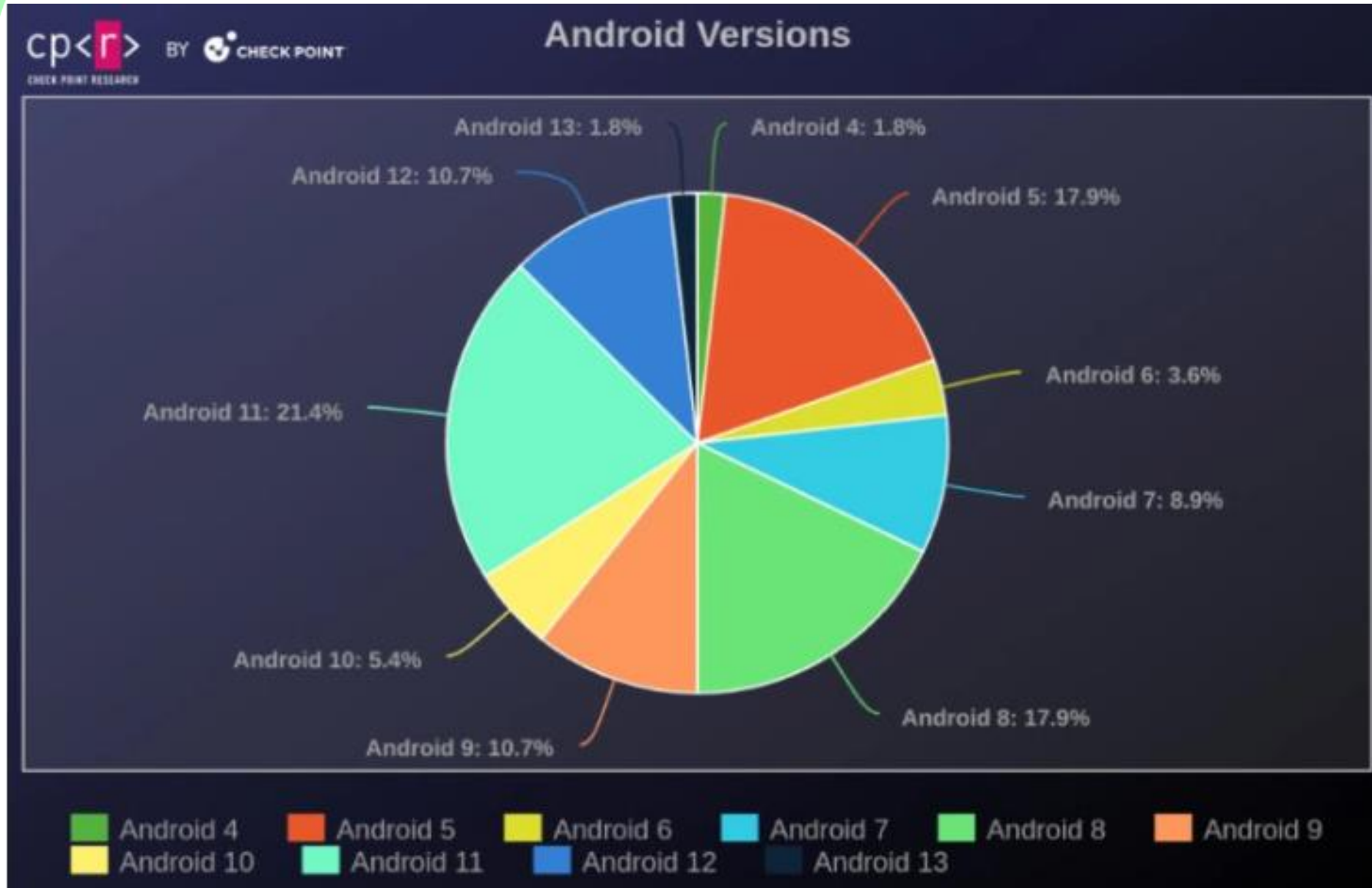
26.06.2024

Tempo est. de leitura: 7 minutos

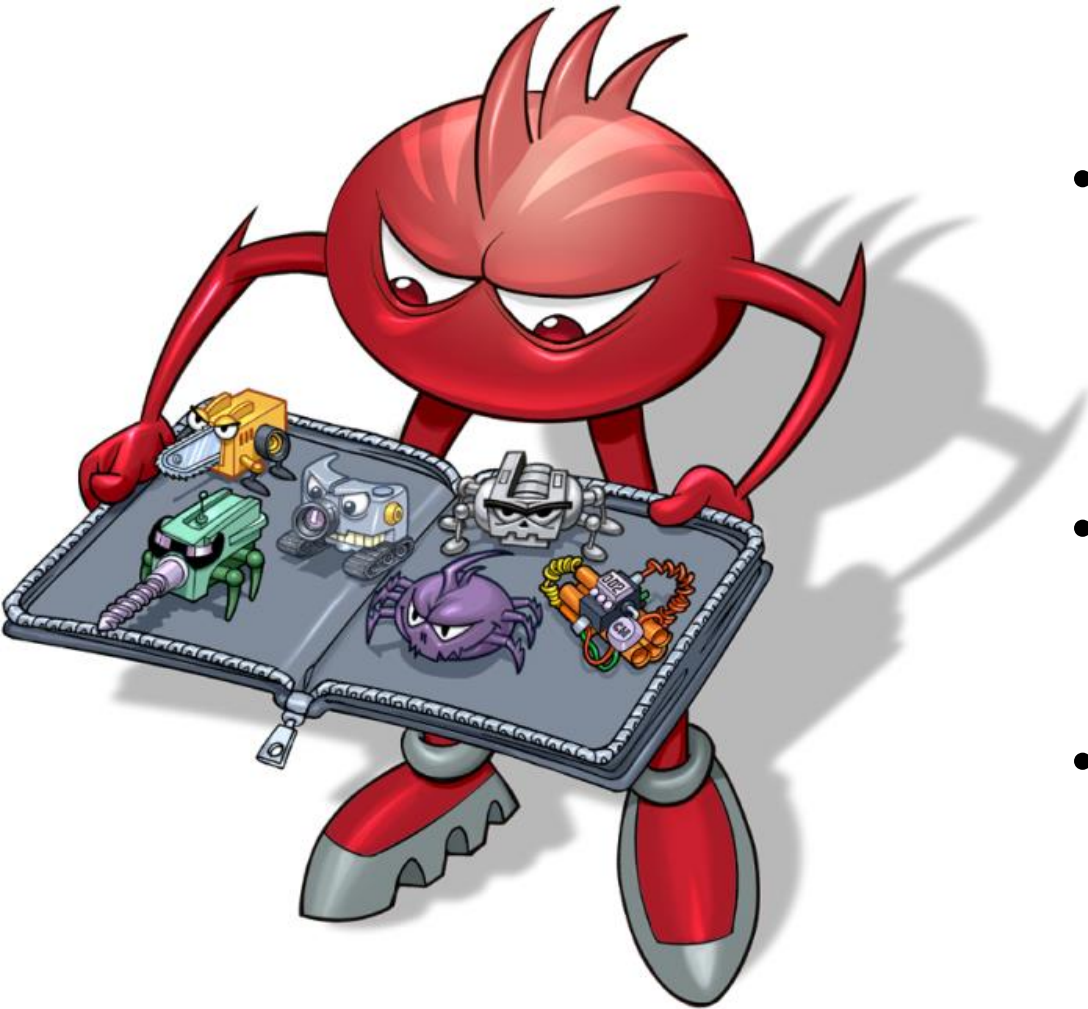
Atualizado em 27.06.2024

Fonte: <https://urmobo.com.br/blog/rafel-rat-como-proteger-dispositivos-android-do-novo-malware/>

Malwares – RAT

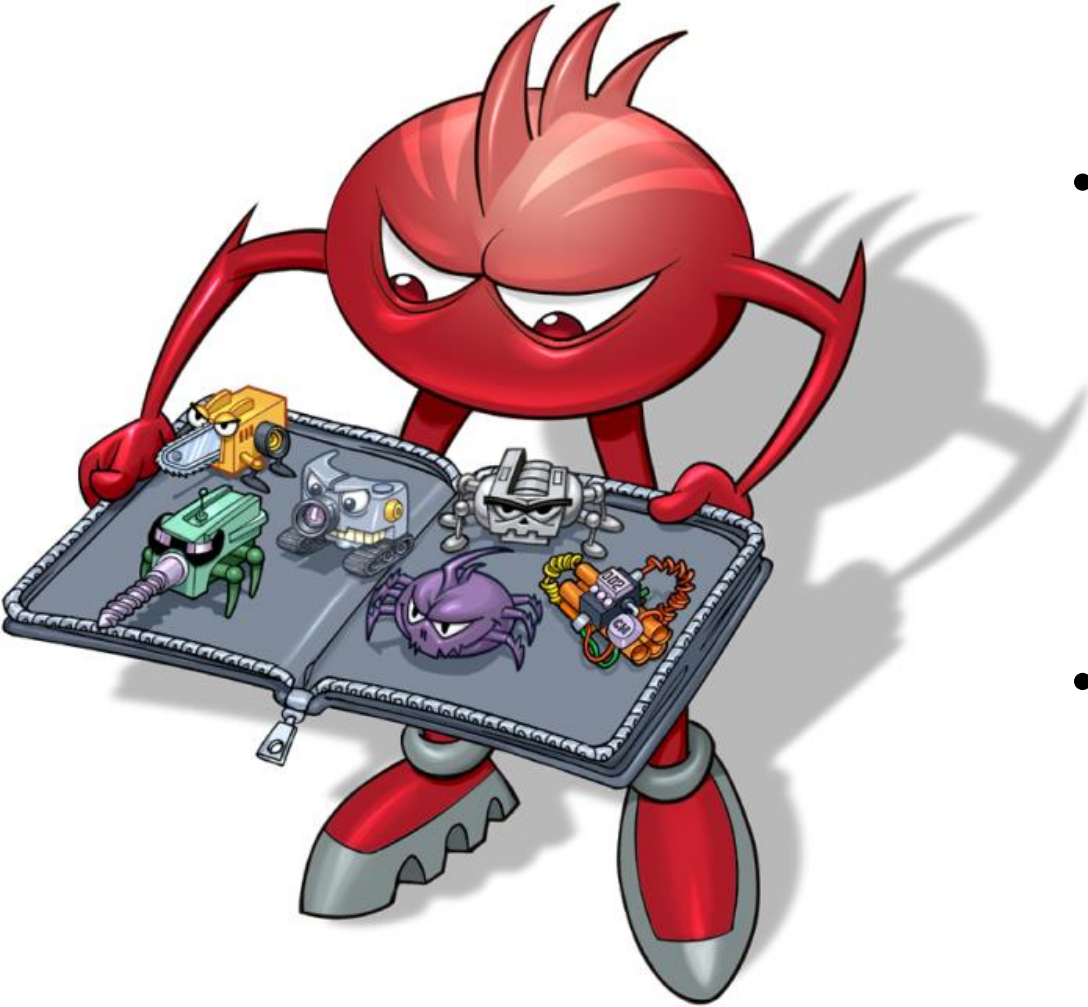


Malwares – Rootkit



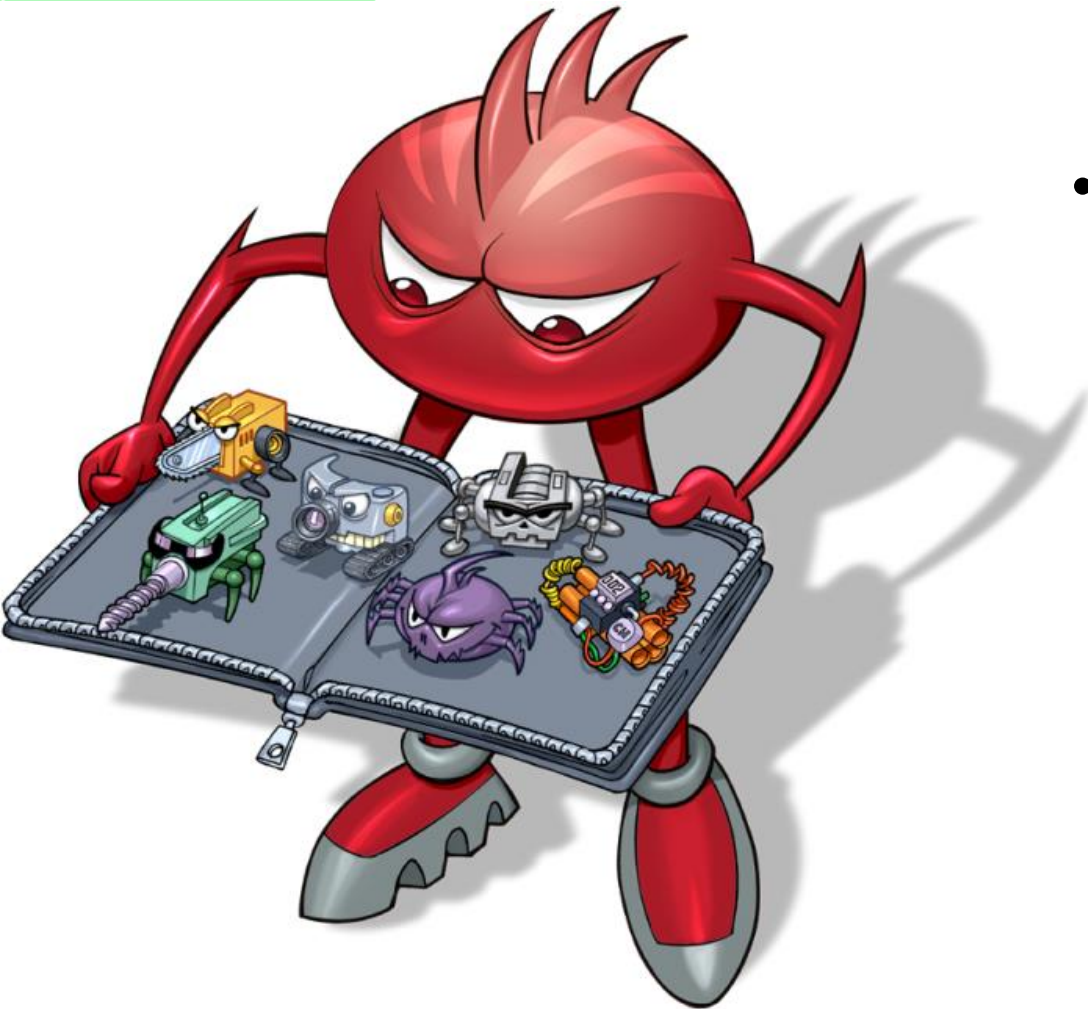
- É um **conjunto de programas e técnicas** que permitem **esconder** e assegurar a presença de um **Atacante** ou Malware em um dispositivo;
- De forma geral, o RootKit vai **permitir** o Atacante obter **acesso** como **administrador** ao dispositivo;
- Com esse tipo de acesso, ele poderá fazer alterações no **Sistema Operacional** e desabilitar medidas de segurança;

Malwares – Rootkit



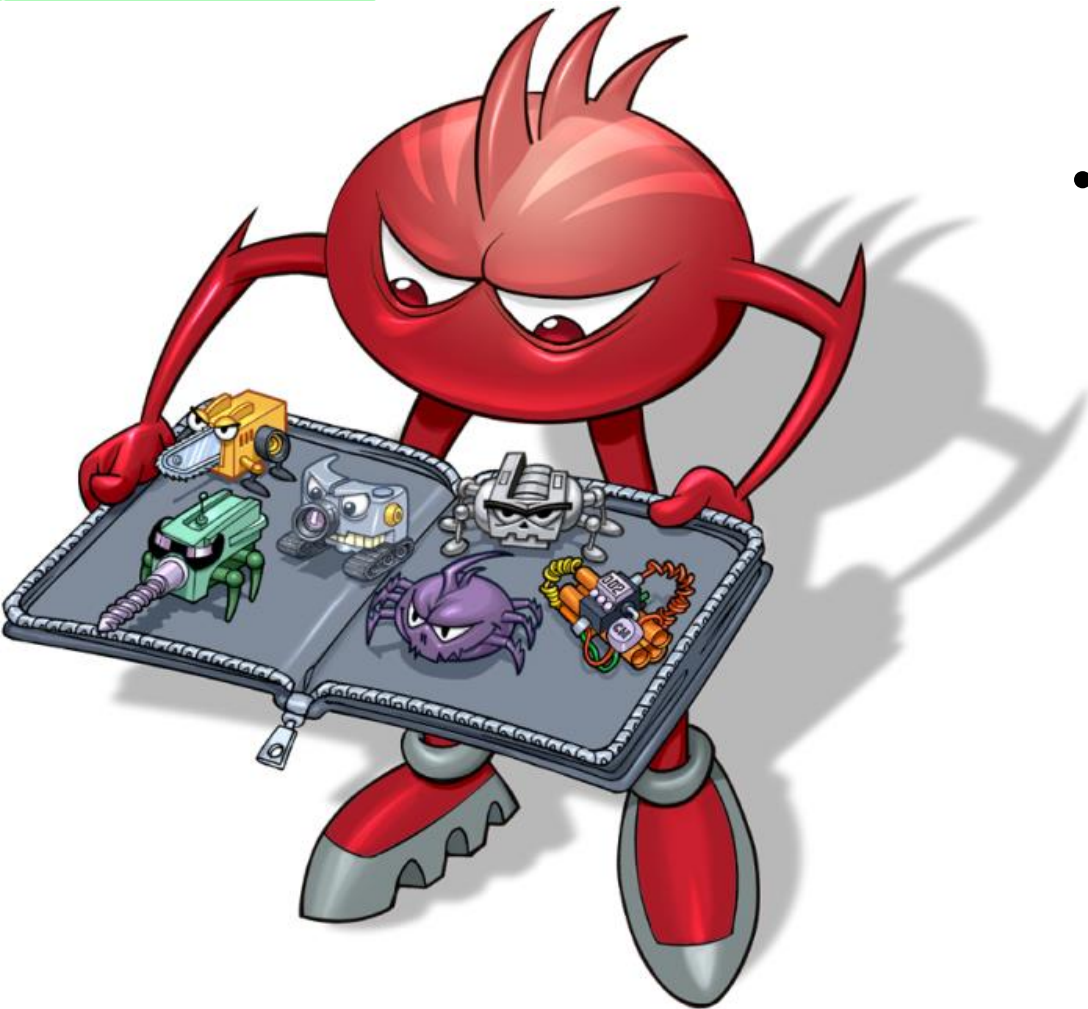
- A origem desse nome é da **junção** da palavra “**root**”, que é o usuário com maiores privilégios em sistemas de base Unix;
- E a palavra “**kit**”, que remete ao conjunto de programas, que nesse caso são programas que irão manter o privilégio de acesso do Atacante;

Malwares – Rootkit



- **ZeroAccess:**
 - Descoberto em 2011 e classificado como **BotNet**, mas possui um RootKit efetivo para garantia de acesso;
 - O seu RootKit é de modo Kernel, e chegou a **infectar** cerca de **2 milhões de dispositivos** no mundo;
 - A infecção é em estágios, se inicia com o acesso a um **site** controlado pelos atacantes que executará **scripts PHP maliciosos**;

Malwares – Rootkit



- **ZeroAccess:**

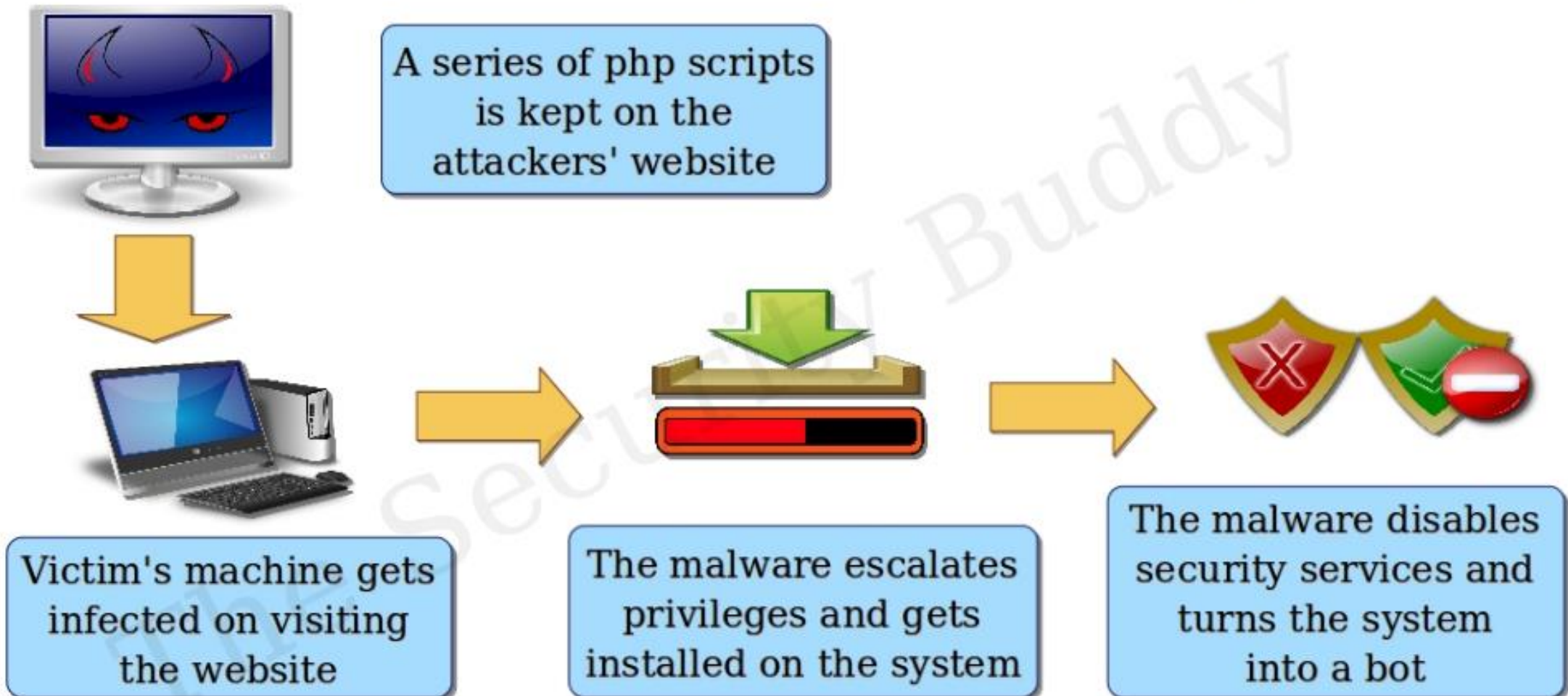
- Esses scripts irão **explorar vulnerabilidades** para conseguir se instalar no dispositivo;
- Ao conseguir **privilegio de administrador**, ele poderá **desabilitar o firewall** ou **corromper serviços** do sistema para sua finalidade;
- Por fim, ele transforma o dispositivo em um **Zumbi** para utilização em ataques cibernéticos;
- **Esse malware ainda está em atividade.**

Malwares – Rootkit

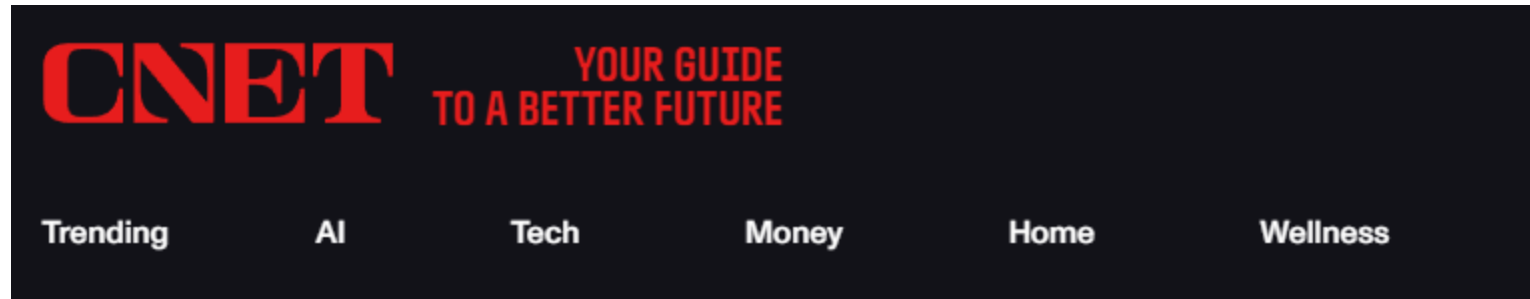
ZeroAccess Rootkit



The Security Buddy
<https://www.thesecuritybuddy.com/>



Malwares – Rootkit



News > Privacy

Symantec takes on one of largest botnets in history

The security firm is confronting the ZeroAccess botnet, which is likely to have more than 1.9 million slave computers at its disposal for click fraud and bitcoin mining.



Charlie Osborne

Oct. 1, 2013 7:34 a.m. PT

2 min read 

IMPACT OF ZEROACCESS BOTNET



One of the largest P2P
botnets ever known

X 1.9 million

ZeroAccess carries out two
revenue generation activities



BITCOIN MINING



CLICK FRAUD

***Botnet generates...**

*Botnet generates...

1.9M x 

Earns US\$ **2,165/day**

Click fraud generates
488 TB network
traffic/day

Per annum earnings:
Tens of millions US\$!!!

Uses



3,458 MWh/day

=



Power for > **111,000**
homes/day

Cost of electricity > US\$ 560,887/day

Sources

<http://www.eia.gov/tools/faqs/faq.cfm?id=97&t=3>
http://www.eia.gov/electricity/monthly/epm_table_grapher.cfm?t=epmt_5_6_a
<http://www.symantec.com/connect/symantec-blogs/sr>

SEP2013

* Based on a test PC with
Pentium D 945 3.4 GHz CPU running 24 hours a day.
Unit price of electricity of \$0.1622 KWh.
Annual US average home electricity usage of 11280 KWh.

Malwares – Scareware

- É um Malware que faz uso de “Engenharia Social” para **assustar/enganar** o usuário;
- Através de mensagens e pop-ups o Scareware **informa** ao usuário que seu dispositivo está com um (falso) **problema de segurança** e **oferece** uma “**solução**” a esse problema;



Malwares – Scareware

- Obviamente que essa “solução” é que irá comprometer definitivamente o dispositivo;
- Um exemplo é o oferecimento de instalação de um “antivírus” que na realidade pode ser um Trojan ou um RAT, que levará a instalação de outros Malwares ou roubo de informações;



Malwares – Scareware

- **ALC Ransomware:**
 - Esse Scareware se passa por um **Ransomware** e ao infectar um dispositivo, **exibe uma mensagem** de que os **arquivos** foram **criptografados** exigindo resgate;
 - Porém nada foi criptografado, ele **apenas desabilitou o Gerenciador de Tarefas e bloqueou a tela** para exibir o bilhete de resgate;





ALC SCAREWARE PRETENDS TO BE A RANSOMWARE

Malwares – Scareware

ALC

All your files are encrypted and inaccessible

How to decrypt my files?

Instructions

To recover your data, send amount to my wallet below and then send a message to the email: Alc@cock.li and inform that you have sent the amount and Mention cvID, SuffID, personnelID in the same message.

decrypt process

To decrypt, after sending the email to the personnel,
Your payment will be confirmed and your cvID will be sent to the key decryption server then decryption instructions will be sent to you.
Note: file decryption is not possible after a week
Note: The amount paid will be doubled after two days
Note: Decryption tools are unable to decrypt your files due to the randomness of the



wallet:
46yRW1YjGQugZi2CrrX5ENj9boHWD8VqY/bGyv1f9QgvGuqJfUanwzf
EEBuFhu4VqeaQVwqx2ctLPQbFbHjRCja4cak53o
amount:554XMR
cvID:55:988PO88
SuffID:557ek
personnelid :AAnFfndKpKjnkwn7w44444

The ransom amount is doubled two days later

Support email: Alc@cock.li



Malwares



- **Malware sem Arquivo:**
 - É um código malicioso que **não deixa rastro no dispositivo** pois não infecta arquivo ou faz escrita em disco rígido, ele **fica “armazenado” em memória** de onde é executado;
 - Sua primeira aparição foi em 2017, mas utiliza **técnicas já conhecidas**, a diferença está na falta de rastreo e uso de armazenamento;
 - Outro ponto é difícil detecção, já que ele **não infecta programas ou arquivos** que o “AntiVírus” normalmente faz sua verificação;

Malwares



- **Malware sem Arquivo:**
 - **IcedID:** É um Malware descoberto em 2017 com o objetivo de roubar dados bancários. Ele é capaz de injetar código HTML e JavaScript no conteúdo do site antes da renderização no navegador. Dessa forma, ele captura e extrai as credenciais do usuário e envia para o Atacante;
 - Sua evasão se dá pelo não monitoramento de execução de código em memória;
 - Em 2022 ele voltou a aparecer, agora como meio para um ataque de Ransomware, onde sua distribuição foi por email que carregar o código malicioso na memória do dispositivo.

Malwares



The screenshot shows the CISO Advisor website. At the top, there is a banner for 'isg Provider Lens' with a photo of people working at computers. Below the banner, the website statistics are displayed: 'CISO Advisor: 189.257 page views/mês - 59.659 usuários/mês - 5.081 assinantes'. The navigation bar includes links for 'Anunciar', 'Newsletter', 'Serviços & Soluções', 'Notícias', and 'Home', along with a search bar. The main content area features a 'Cibercrime' category icon and the headline 'Ransomware Quantum usa trojan para ataques rápidos a redes'. The article is attributed to 'Da Redação' and dated '25/04/2022'.

CISO Advisor

CISO Advisor: 189.257 page views/mês - 59.659 usuários/mês - 5.081 assinantes

Anunciar Newsletter Serviços & Soluções Notícias Home

Busca...

Cibercrime

Ransomware Quantum usa trojan para ataques rápidos a redes

Da Redação

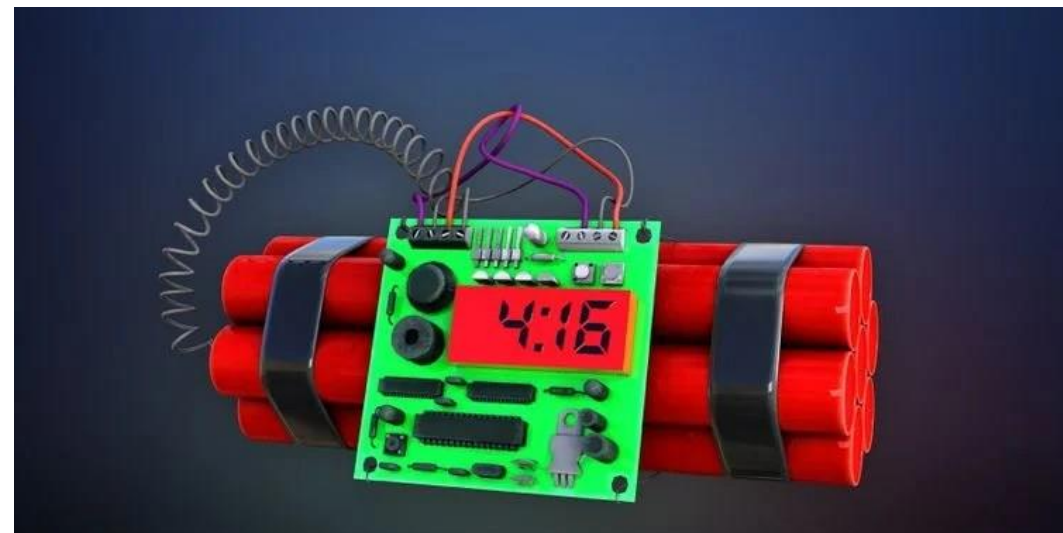
25/04/2022

O ataque detectado usou o malware **IcedID** como o **acesso inicial** à máquina da vítima, que os pesquisadores acreditam ter chegado por meio de um **e-mail de phishing** contendo um anexo.”

Malwares

- **Bombas Lógicas:**

- É um tipo de Malware que tem sua **ativação** **“agendada”** por um evento, com uma **hora** específica ou **quantidade de logons** em um dispositivo;
- Essa Bomba pode **“entregar”** ao sistema um **Malware**, como um Worm, Ransomware, Trojan, ou até mesmo um Backdoor;
- Ou seja, é basicamente um ataque de 2 etapas: **1ª = Infecção**, **2ª = Explosão**;



Malwares



- **Bombas Lógicas:**

- Em 2005 a Sony estava em meio a um escândalo pelo lançamentos de CDs que desencadeavam uma bomba lógica. Ao serem inseridos em um computador, a bomba lógica dos CDs instalava um RootKit que bloqueava a capacidade do Computador de copiar CDs;
- Outro exemplo foi um ataque em 2013 que apagou HDs de bancos e empresas de radiofusão na Coreia do Sul. O grupo responsável pelo ataque enviou e-mails de spam com uma conta comprometida de um banco. Esse e-mail possuía um anexo (Trojan) que ao ser aberto, fazia o download da Bomba Lógica.



Propagação

Propagação

- A forma de **propagação** de um Malware é tão **importante** quanto o **dano** que ele pode causar, já que a sua capacidade de replicação **potencializa** o **Impacto**;
- E sua **interrupção** pode **evitar** que a infecção atinja **seu objetivo**, como um processo específico dentro de uma empresa;
- Como observado, existem algumas **formas de propagação**, comuns em todos (ou na maioria) dos Malwares;



Propagação



- **Email:** Com um **e-mail comprometido**, um Malware pode forçar o dispositivo a **enviar e-mails** com links e/ou anexos **infectados**. Quando o destinatário abrir esse link/anexo, seu computador será infectado e o ciclo se reinicia;



- **Meios Físicos:** **Pendrives** são a forma mais comum de meio físico utilizado para propagação. Muitas vezes, **ao plugar** o dispositivo infectado em um novo computador, o **Malware** já é capaz de **infectar** e se **propagar** pelo novo Sistema Operacional. **Ex:** Autorun.exe;

Propagação



- **Pop-Ups:** Costumam conter **falsas mensagens** e alertas de segurança, **induzindo** os **usuários** a instalar uma “solução” de segurança que na realidade irá **infectar o computador**;



- **Vulnerabilidades:** **Defeitos de segurança** pré-existentes em versões de softwares utilizados;



- **Download Drive-by:** **Download** e instalação **não autorizado** pelo usuário de um software de terceiro;



Propagação

- **Escalada de Privilégios:** **Obtenção** gradual de **acesso** a um dispositivo ou rede que será futuramente **utilizado para Ataques**;



- **Homogeneidade:** **Chance aumentada de infecção** em redes que possuem estações de trabalho de **mesmo modelo e versão de software/hardware** (devido a desatualização ou vulnerabilidade);





Prevenção

Prevenção

- Segundo o CERT.BR (2023), a maneira mais eficaz de prevenção contra Malwares, é **evitar a sua infecção**;  Centro de Estudos, Resposta e Tratamento de Incidentes de Segurança no Brasil
CERT Nacional de Último Recurso
- A Kaspersky Lab (2024) divide a prevenção em **duas etapas**:
 - **Vigilância Pessoal**: **Primeira camada de Proteção**, pois os Malwares costumam se **propagar por e-mail**, com anexos e links. Logo, o **primeiro filtro é o usuário**, se ele abrirá ou não a mensagem;
 - **Ferramentas de Proteção**: Nessa **segunda camada** entram os AntiMalwares, **softwares** que rotineiramente **verificam arquivos e programas** instalados no computador.

OBS: O termo **AntiVírus** está **incorreto**, já que os “AntiVírus” não identificam apenas Vírus;

Prevenção



- Logo, é uma recomendação **ter cuidado com e-mails**, mesmo que de fontes confiáveis;
- Assim como **possuir um AntiMalware** instalado em seu computador;
 - E para as empresas, instalados em **TODAS** as **estações de trabalho**;
 - Lembrem-se “A Segurança é tão forte quanto o elo mais fraco da cadeia”.
- Além de instalado, é importante a sua configuração e **constante atualização**;
 - Além da **verificação** rotineira e **automática dos arquivos**.

Prevenção



- Adicionalmente ao AntiMalware, o [CERT.BR](#) (2023) recomenda ter um [Firewall](#) pessoal instalado e ativo;
- O uso de [Firewall em empresas é comum](#), e por se tratar de um ambiente corporativo faz-se necessário um Firewall de maior capacidade;
 - Normalmente [Firewalls](#) assim [necessitam de configuração manual](#);
 - É necessária [atenção](#) para essa configuração estar alinhada à [política e necessidade da empresa](#).

Prevenção

- Também é necessário a **atualização** rotineira **de Sistemas e Aplicativos**, pois muitos Malwares (e Atacantes) exploram vulnerabilidades conhecidas de versões desatualizadas de softwares;
 - Essas atualizações trazem **correções de segurança** que evitam a exploração de vulnerabilidades;
 - Obviamente que algumas atualizações podem trazer **bugs e criar novas vulnerabilidades**, fiquem sempre atentos;



Prevenção

- O CERT.BR (2023) também dá algumas **recomendações** de prevenção:

- Nunca clique em links desconhecidos:

- O link pode ser malicioso e redirecionar você para um site que contém um Malware que infectará o seu computador pelo simples acesso (Malware sem Arquivo), ou adicionando “cookies” em seu navegador.

- Desconfie dos anexos:

- Apesar de alguns e-mails parecerem fora de contexto, outros **podem possuir conteúdo que desperte o interesse** e leve você a fazer o download que infectará o computador. **Ex:** fatura de cartão ou aviso de seu banco.



Prevenção

- O CERT.BR (2023) também dá algumas **recomendações** de prevenção:
 - Baixe programas e aplicativos apenas de lojas oficiais:
 - Isso irá reduzir a probabilidade de instalar um aplicativo falso ou com um Malware inserido em seu código fonte. **A lojas oficiais detectam e bloqueiam aplicativos inseguros** com maior rapidez. **Ex:** uTorrent.
 - Tenha uma rotina de Backups:
 - Isso **reduz o Impacto de um Malware** que exclua ou bloqueie seus arquivos;



Prevenção

- O CERT.BR (2023) também dá algumas **recomendações** de prevenção:

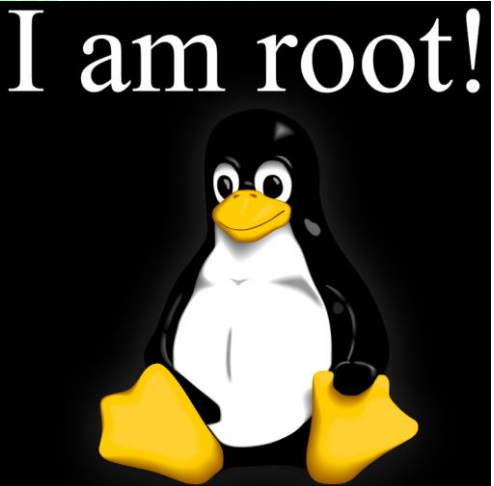
- Utilize Autenticação Forte:

- Um exemplo é a **autenticação de dois fatores**, ela evita que mesmo com o roubo de sua senha um Atacante consiga acessar sua conta de e-mail por exemplo.
- Também é interessante **não repetir senhas**, já que o vazamento de uma pode levar à exposição em vários Apps;
- **Nunca salvar senha no navegador**, justamente por existirem Malwares que conseguem interceptá-las;



Prevenção

- O CERT.BR (2023) também dá algumas **recomendações** de prevenção:



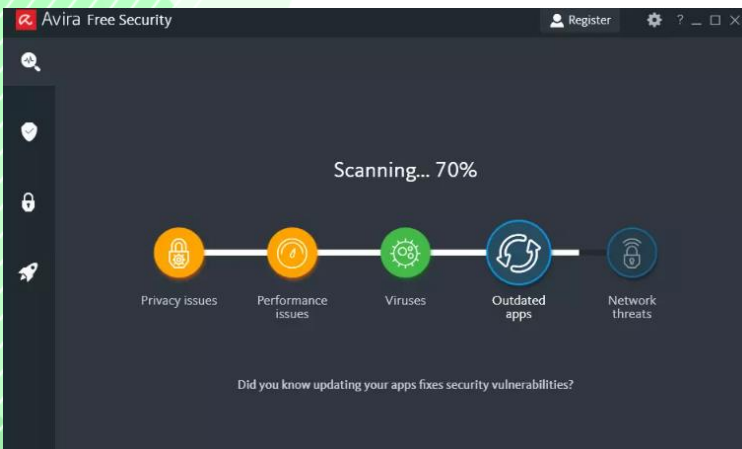
- Use a conta de Administrador apenas quando necessário:
 - O privilégio de acesso de um Malware é o mesmo do usuário que o ativou, ou seja, se a sua conta de usuário for restrita o Malware não será capaz de danificar arquivos de sistema, instalar ou desinstalar softwares, etc;
 - Esse é o Princípio o “**Privilégio Mínimo**”, ter acesso a somente o que é necessário.

Prevenção

- O CERT.BR (2023) também dá algumas **recomendações** de prevenção:

- Em caso exposição a algum Malware, aja rapidamente:

- Atualize e use o seu **AntiMalware** para detectar a infecção;
- **Reinicie o dispositivo**, eficaz contra Malwares que atacam a memória como em Roteadores e dispositivos IoT;
- E por último, caso nada surta efeito, **reinstale o sistema** (ou retornar a configuração de fábrica);
- Não esqueça também de **alterar suas senhas**, já que não se sabe ao que o Malware teve acesso.

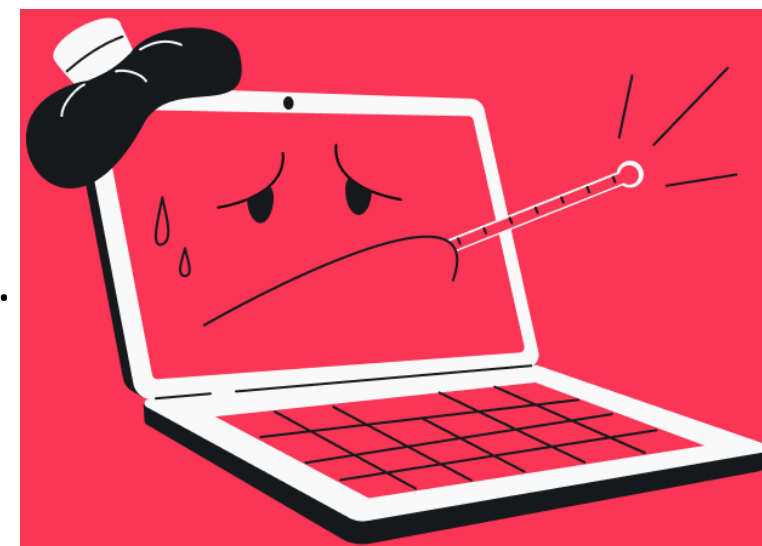




Considerações Finais

Considerações Finais

- Nesta aula aprendemos sobre **Malwares**, erroneamente chamados de “Vírus” pela mídia;
- Eles **executam ações danosas e maliciosas** além de poderem ser intermediários em Golpes mais elaborados;
- Os Malwares **exploram e/ou criam vulnerabilidades**, e possuem **vários tipos**, de acordo com a sua funcionalidade;
 - Vírus, Ransomware, Spyware, Worm, Bot, Trojan, Backdoor, Rootkit e Scareware, além de outros tipos.



Considerações Finais

- Também vimos sobre as **principais formas de propagação** dos Malwares, sendo **emails e pendrives** os principais deles;
- E por fim, as **formas de prevenção**, que de forma geral é prevenir a infecção;
 - Essa prevenção pode ser **dividida em 2 etapas**: Vigilância Pessoal e Ferramentas de Proteção;
 - **Vigilância Pessoal** para como uma forma das pessoas se conscientizarem e se policiarem;
 - E as **Ferramentas**, como Anti-Malwares e Firewalls para auxiliarem nisso.



Referências



- **Centro de Estudos, Resposta e Tratamento de Incidentes de Segurança no Brasil, CERT.br. Cartilha de Segurança para Internet. 2 ed. Comitê Gestor da Internet no Brasil: São Paulo, 2012. Disponível em: <https://cartilha.cert.br/livro/>.**
- **Centro de Estudos, Resposta e Tratamento de Incidentes de Segurança no Brasil, CERT.br. Códigos Maliciosos. Comitê Gestor da Internet no Brasil: São Paulo, 2023. Disponível em: <https://cartilha.cert.br/fasciculos/#codigos-maliciosos>.**
- **CYFIRMA. ALC SCAREWARE PRETENDS TO BE A RANSOMWARE. Disponível em: <https://www.cyfirma.com/research/alc-scareware-pretends-to-be-a-ransomware/>.**

Referências



- KASPERSKY LAB. **Aprenda sobre malware e como proteger todos os seus dispositivos contra eles.** Disponível em: <https://www.kaspersky.com.br/resource-center/preemptive-safety/what-is-malware-and-how-to-protect-against-it>.
- KASPERSKY LAB. **Quais são os diferentes tipos de Malware?** Disponível em: <https://www.kaspersky.com.br/resource-center/threats/types-of-malware>.
- SÊMOLA, M. **Gestão da Segurança da Informação:** uma visão Executiva. Rio de Janeiro: 2. ed. Campus, 2014.
- THE SECURITY BUDDY. **What is the ZeroAccess rootkit?.** Disponível em: <https://www.thesecuritybuddy.com/preventing-rootkits/what-is-zeroaccess-rootkit/>.
- URMOBO MDM. **Rafel RAT:** Como proteger dispositivos Android do novo malware. Disponível em: <https://urmobo.com.br/blog/rafel-rat-como-proteger-dispositivos-android-do-novo-malware/>.

